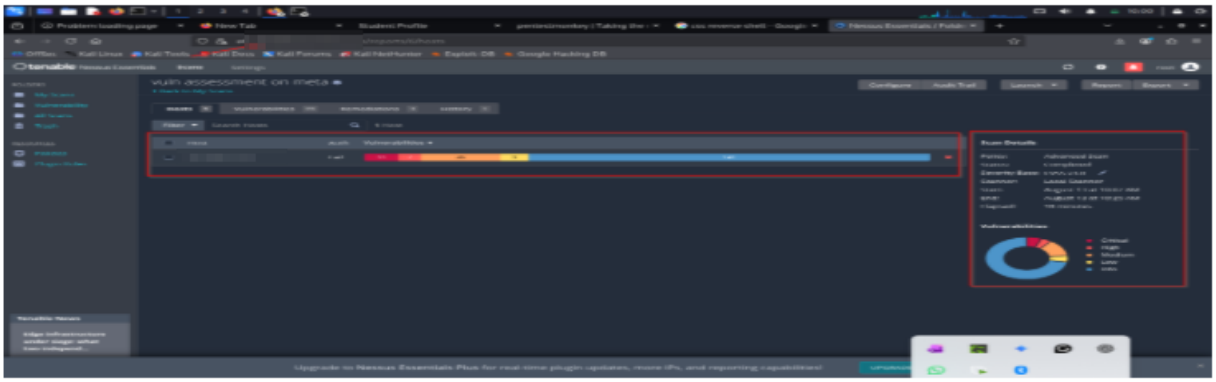
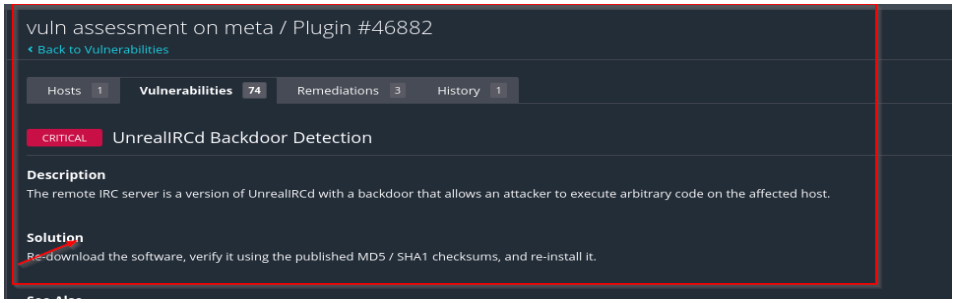
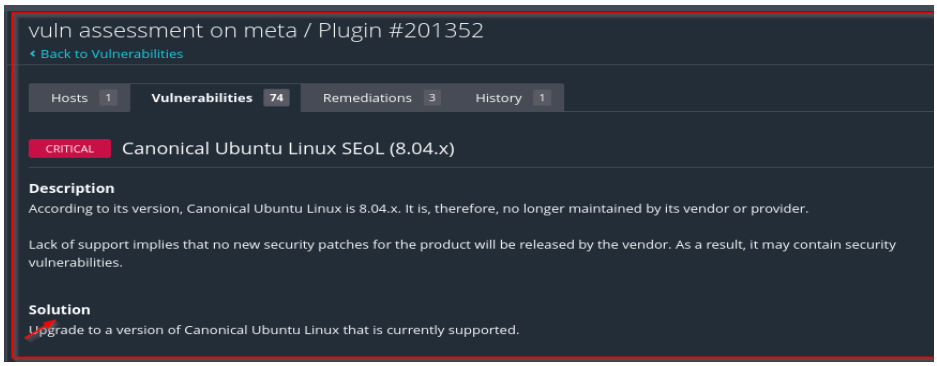
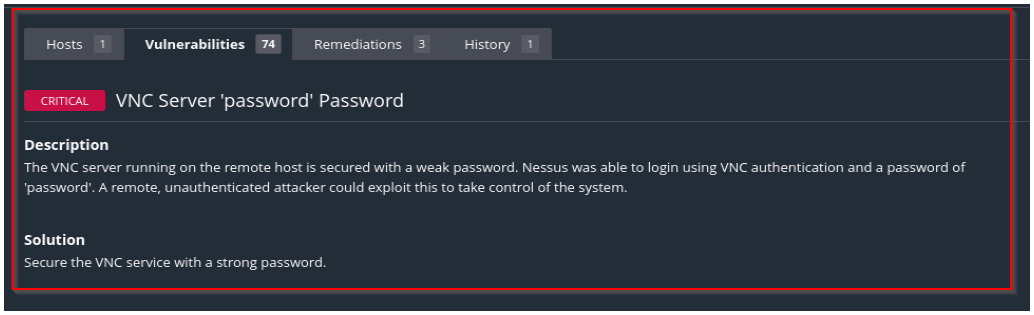
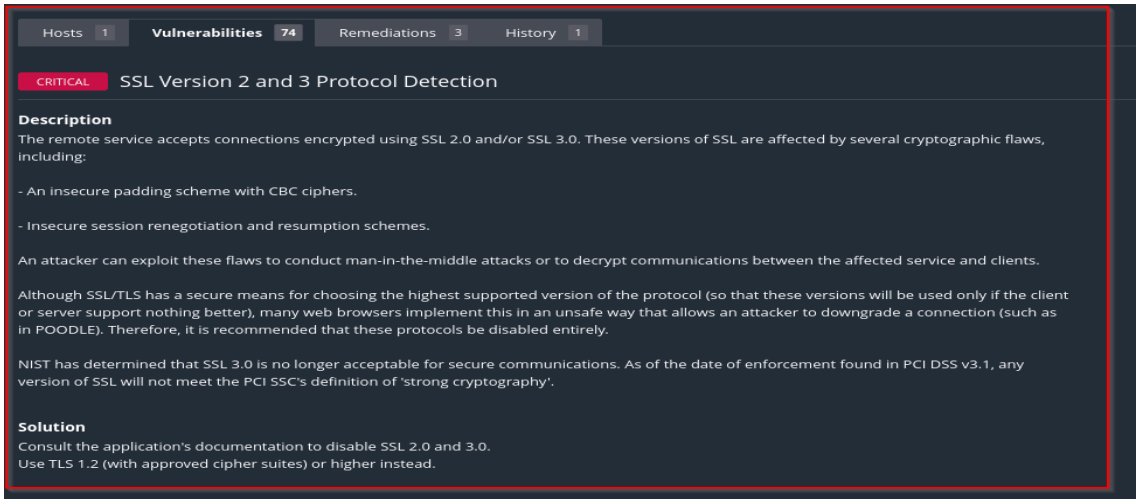
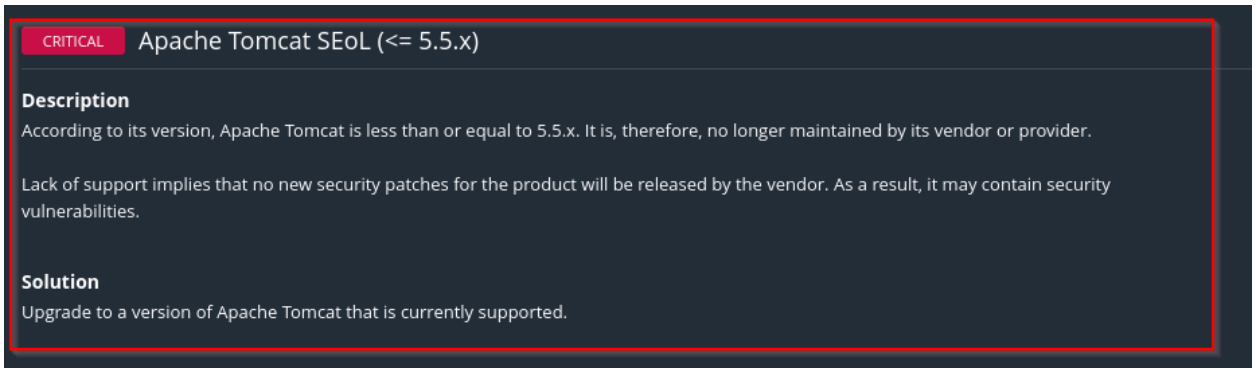


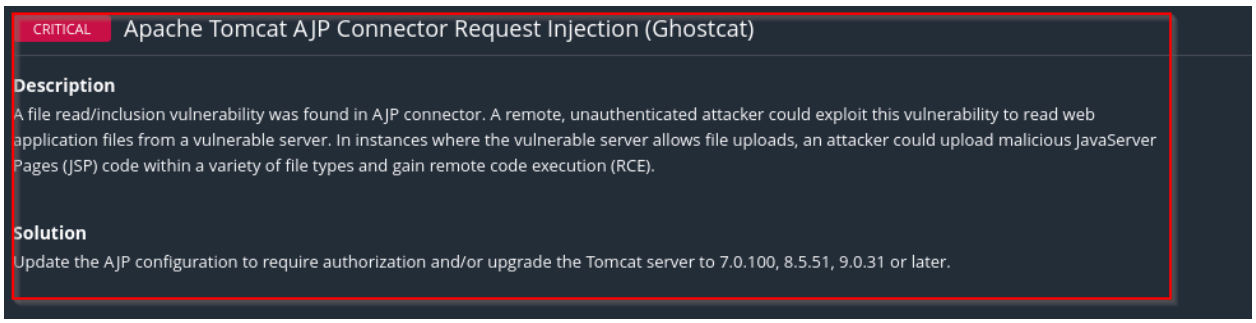

vuln assessment on meta / Plugin #46882
Back to Vulnerabilities
Hosts 1
Vulnerabilities 74
Remediations 3
History 1
CRITICAL
UnrealIRCd Backdoor Detection
Description
The remote IRC server is a version of UnrealIRCd with a backdoor that allows an attacker to execute arbitrary code on the affected host.
Solution
Re-download the software, verify it using the published MD5 / SHA1 checksums, and re-install it.

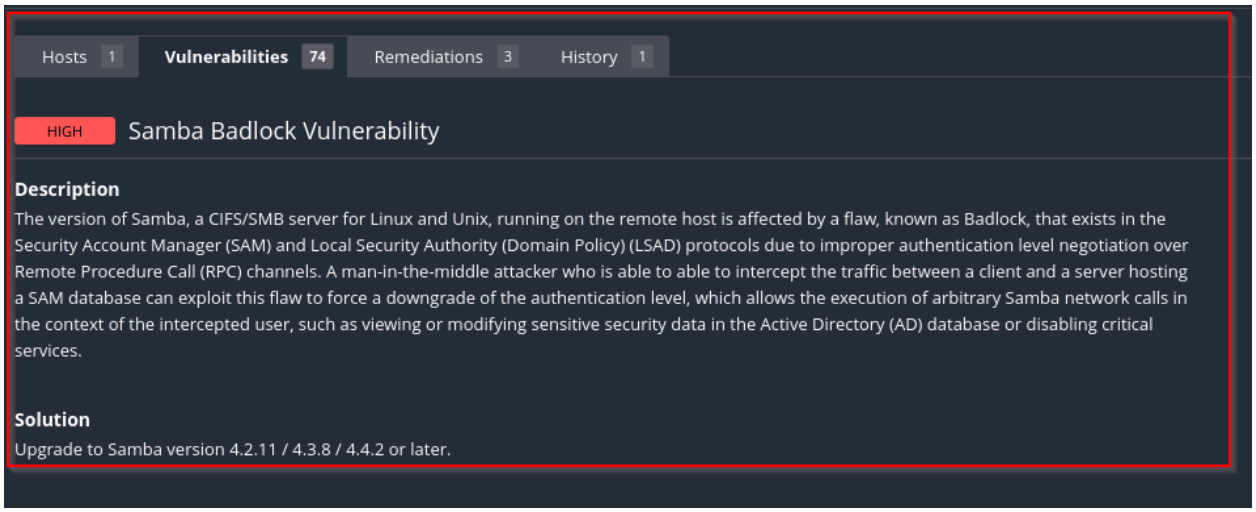

vuln assessment on meta / Plugin #201352
Back to Vulnerabilities
Hosts 1
Vulnerabilities 74
Remediations 3
History 1
CRITICAL
Canonical Ubuntu Linux SEoL (8.04.x)
Description
According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider.
Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.
Solution
Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

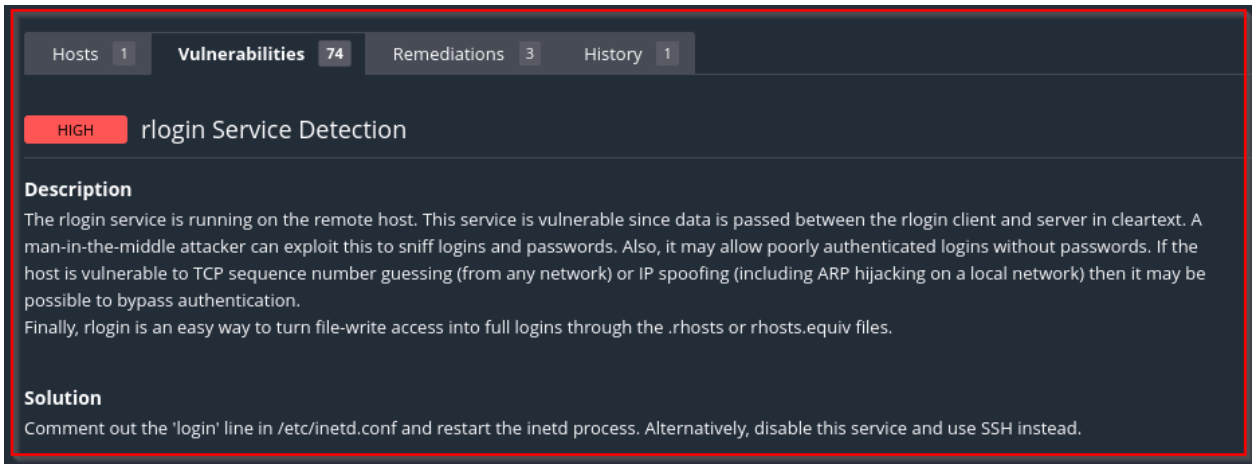

Hosts 1
Vulnerabilities 74
Remediations 3
History 1
CRITICAL
VNC Server 'password' Password
Description
The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.
Solution
Secure the VNC service with a strong password.

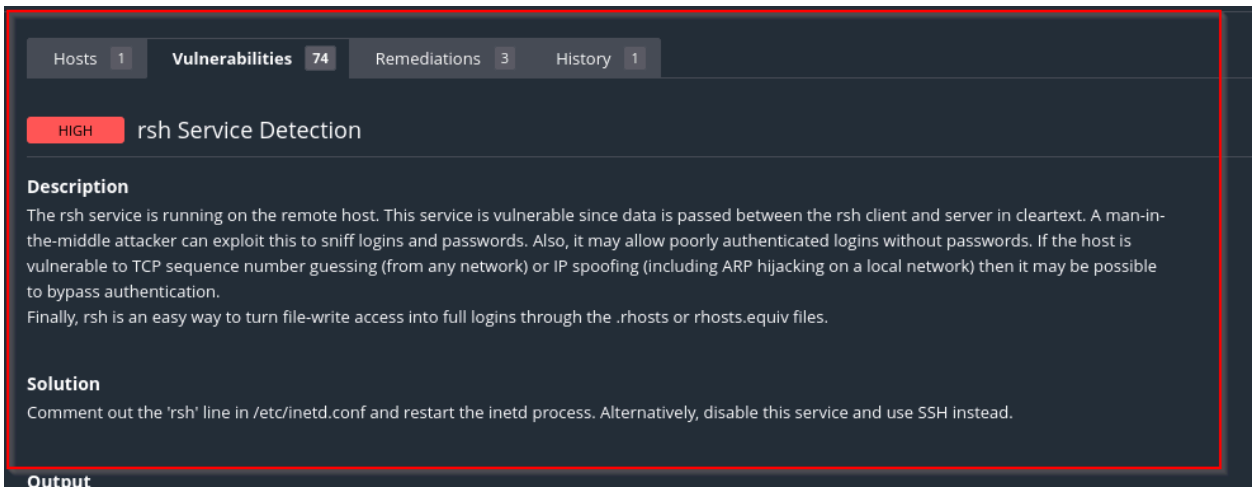

Hosts 1
Vulnerabilities 74
Remediations 3
History 1
CRITICAL
SSL Version 2 and 3 Protocol Detection
Description
The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:
- An insecure padding scheme with CBC ciphers.
- Insecure session renegotiation and resumption schemes.
An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.
Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.
NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.
Solution
Consult the application's documentation to disable SSL 2.0 and 3.0.
Use TLS 1.2 (with approved cipher suites) or higher instead.

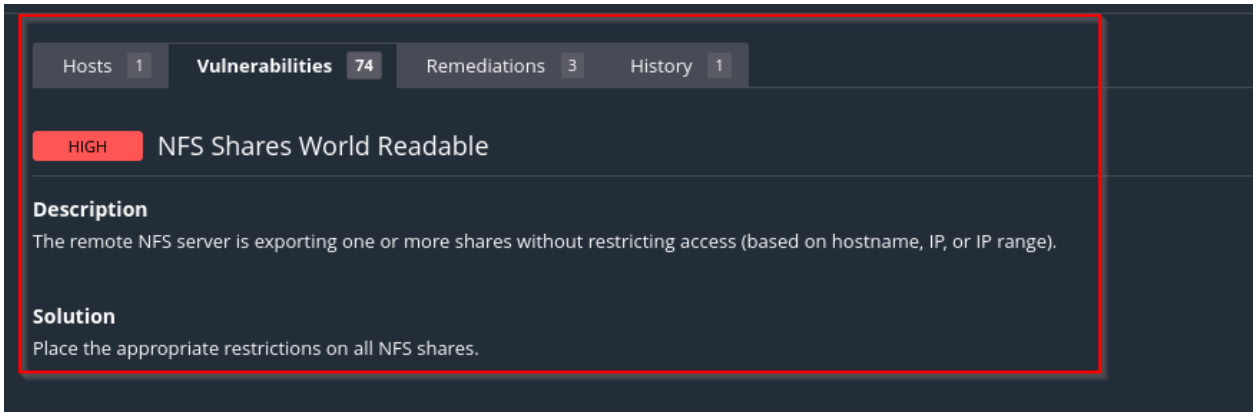

CRITICAL
Apache Tomcat SEoL (<= 5.5.x)
Description
According to its version, Apache Tomcat is less than or equal to 5.5.x. It is, therefore, no longer maintained by its vendor or provider.
Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.
Solution
Upgrade to a version of Apache Tomcat that is currently supported.

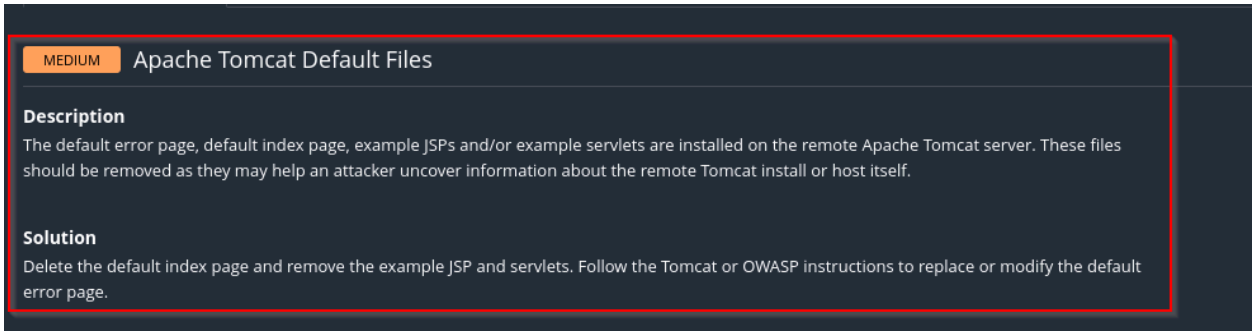

CRITICAL
Apache Tomcat AJP Connector Request Injection (Ghostcat)
Description
A file read/inclusion vulnerability was found in AJP connector. A remote, unauthenticated attacker could exploit this vulnerability to read web application files from a vulnerable server. In instances where the vulnerable server allows file uploads, an attacker could upload malicious JavaServer Pages (JSP) code within a variety of file types and gain remote code execution (RCE).
Solution
Update the AJP configuration to require authorization and/or upgrade the Tomcat server to 7.0.100, 8.5.51, 9.0.31 or later.

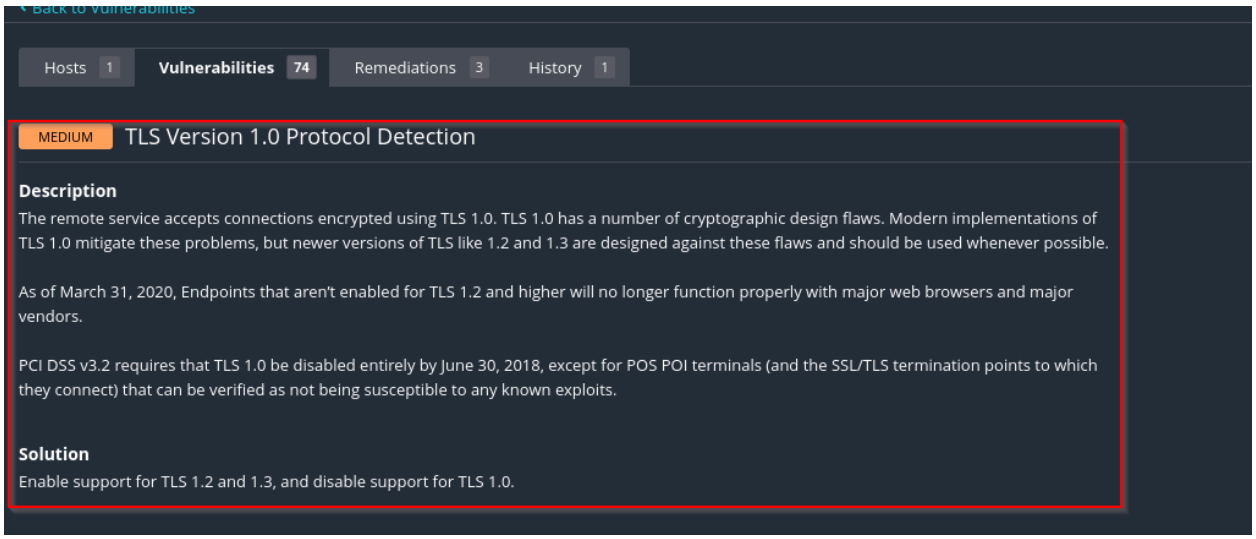

Hosts 1
Vulnerabilities 74
Remediations 3
History 1
HIGH
Samba Badlock Vulnerability
Description
The version of Samba, a CIFS/SMB server for Linux and Unix, running on the remote host is affected by a flaw, known as Badlock, that exists in the Security Account Manager (SAM) and Local Security Authority (Domain Policy) (LSAD) protocols due to improper authentication level negotiation over Remote Procedure Call (RPC) channels. A man-in-the-middle attacker who is able to able to intercept the traffic between a client and a server hosting a SAM database can exploit this flaw to force a downgrade of the authentication level, which allows the execution of arbitrary Samba network calls in the context of the intercepted user, such as viewing or modifying sensitive security data in the Active Directory (AD) database or disabling critical services.
Solution
Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.

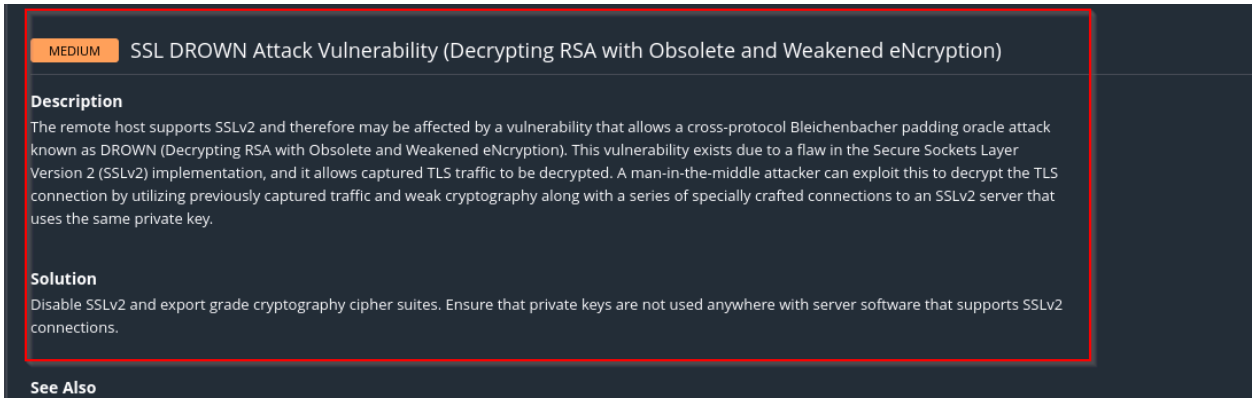

Hosts 1
Vulnerabilities 74
Remediations 3
History 1
HIGH
rlogin Service Detection
Description
The rlogin service is running on the remote host. This service is vulnerable since data is passed between the rlogin client and server in cleartext. A man-in-the-middle attacker can exploit this to sniff logins and passwords. Also, it may allow poorly authenticated logins without passwords. If the host is vulnerable to TCP sequence number guessing (from any network) or IP spoofing (including ARP hijacking on a local network) then it may be possible to bypass authentication.
Finally, rlogin is an easy way to turn file-write access into full logins through the .rhosts or rhosts.equiv files.
Solution
Comment out the 'login' line in /etc/inetd.conf and restart the inetd process. Alternatively, disable this service and use SSH instead.

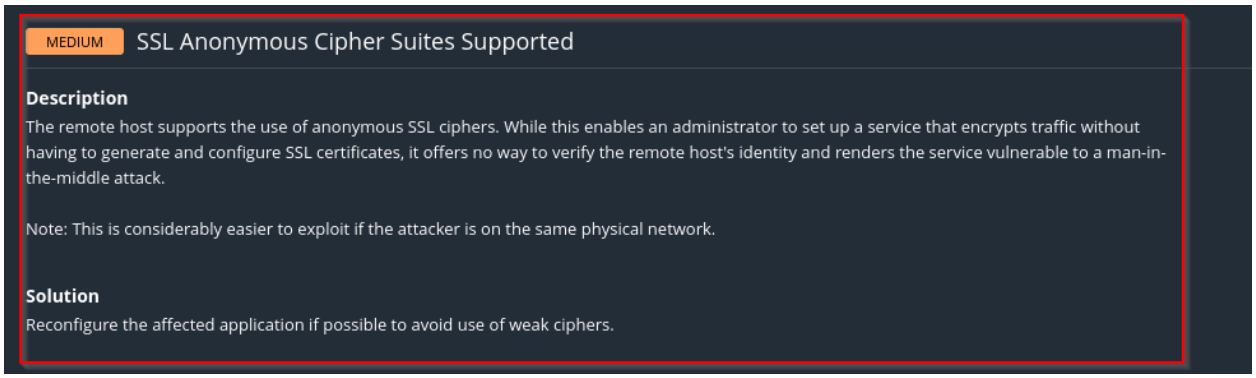

Hosts 1
Vulnerabilities 74
Remediations 3
History 1
HIGH
rsh Service Detection
Description
The rsh service is running on the remote host. This service is vulnerable since data is passed between the rsh client and server in cleartext. A man-in-the-middle attacker can exploit this to sniff logins and passwords. Also, it may allow poorly authenticated logins without passwords. If the host is vulnerable to TCP sequence number guessing (from any network) or IP spoofing (including ARP hijacking on a local network) then it may be possible to bypass authentication.
Finally, rsh is an easy way to turn file-write access into full logins through the .rhosts or rhosts.equiv files.
Solution
Comment out the 'rsh' line in /etc/inetd.conf and restart the inetd process. Alternatively, disable this service and use SSH instead.
Output

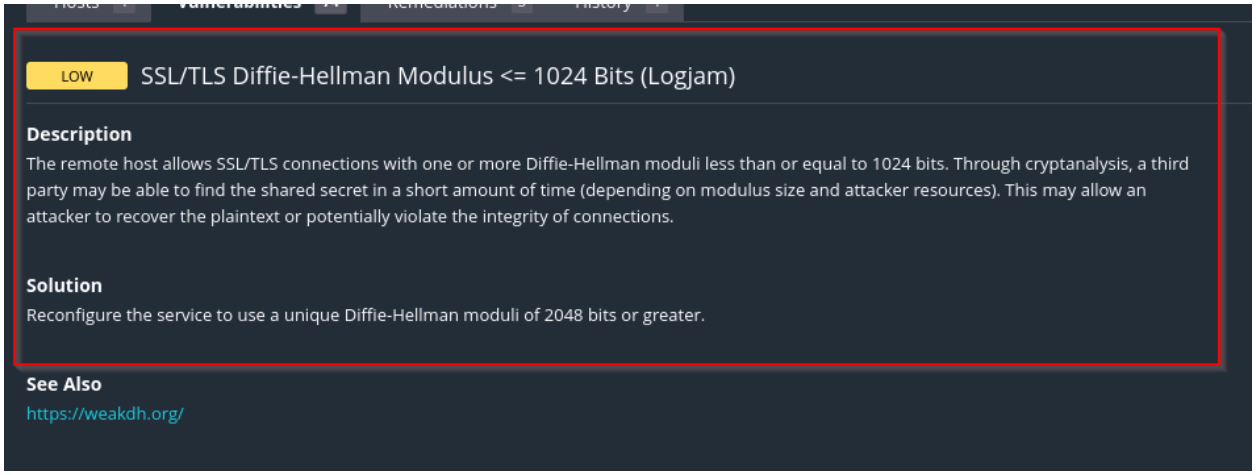

Hosts 1
Vulnerabilities 74
Remediations 3
History 1
HIGH
NFS Shares World Readable
Description
The remote NFS server is exporting one or more shares without restricting access (based on hostname, IP, or IP range).
Solution
Place the appropriate restrictions on all NFS shares.

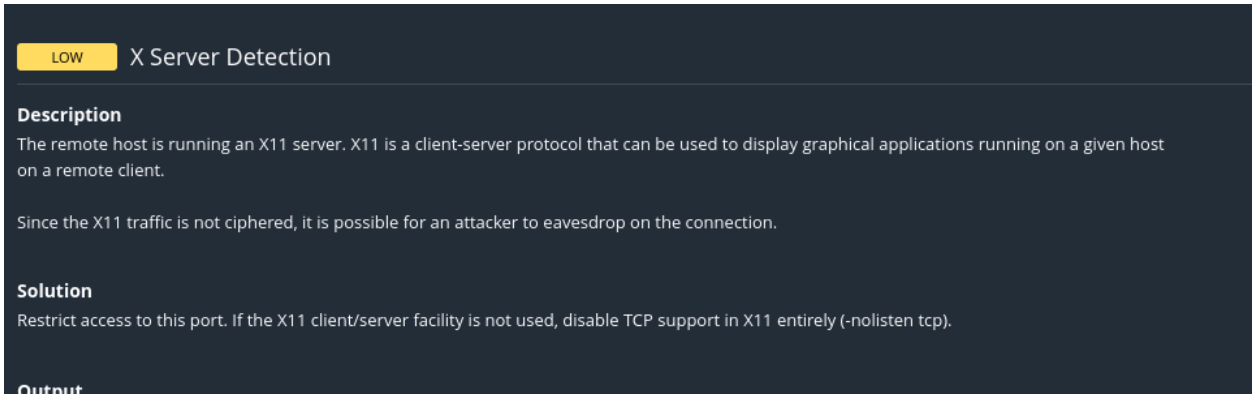

MEDIUM
Apache Tomcat Default Files
Description
The default error page, default index page, example JSPs and/or example servlets are installed on the remote Apache Tomcat server. These files should be removed as they may help an attacker uncover information about the remote Tomcat install or host itself.
Solution
Delete the default index page and remove the example JSP and servlets. Follow the Tomcat or OWASP instructions to replace or modify the default error page.

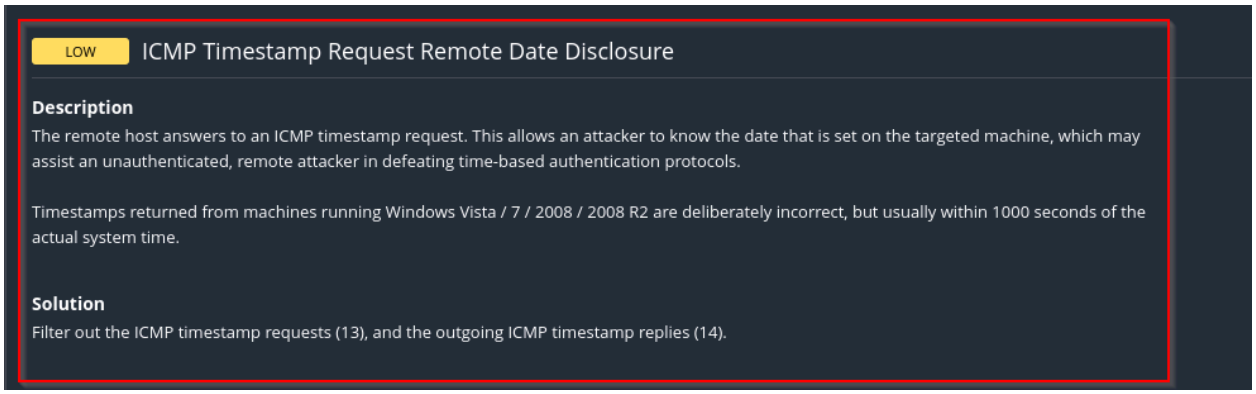

Hosts 1
Vulnerabilities 74
Remediations 3
History 1
MEDIUM
TLS Version 1.0 Protocol Detection
Description
The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.
As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.
PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.
Solution
Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

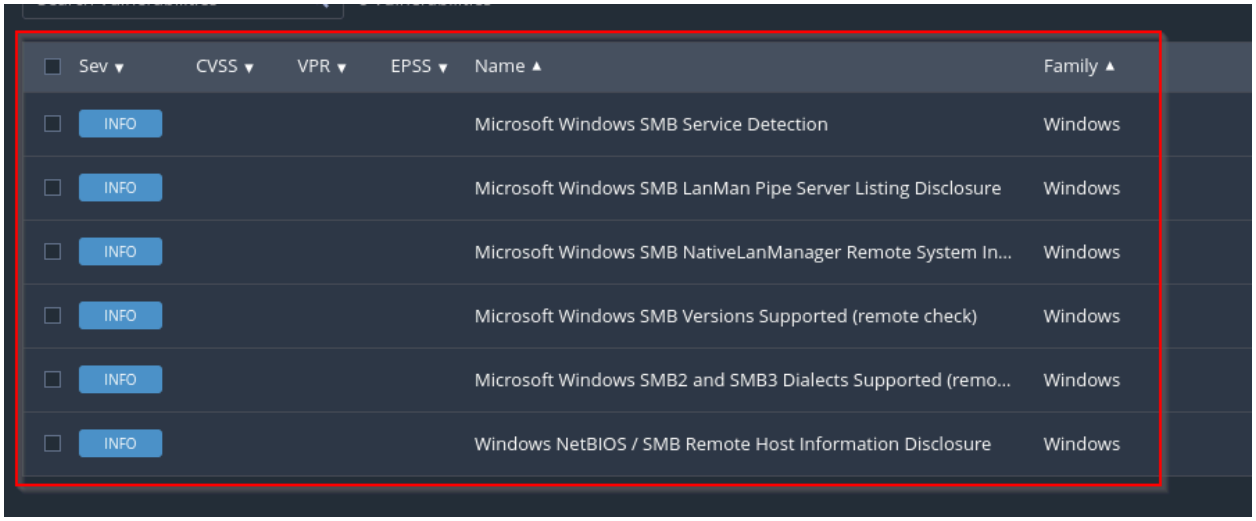

MEDIUM
SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)
Description
The remote host supports SSLv2 and therefore may be affected by a vulnerability that allows a cross-protocol Bleichenbacher padding oracle attack known as DROWN (Decrypting RSA with Obsolete and Weakened eNcryption). This vulnerability exists due to a flaw in the Secure Sockets Layer Version 2 (SSLv2) implementation, and it allows captured TLS traffic to be decrypted. A man-in-the-middle attacker can exploit this to decrypt the TLS connection by utilizing previously captured traffic and weak cryptography along with a series of specially crafted connections to an SSLv2 server that uses the same private key.
Solution
Disable SSLv2 and export grade cryptography cipher suites. Ensure that private keys are not used anywhere with server software that supports SSLv2 connections.
See Also

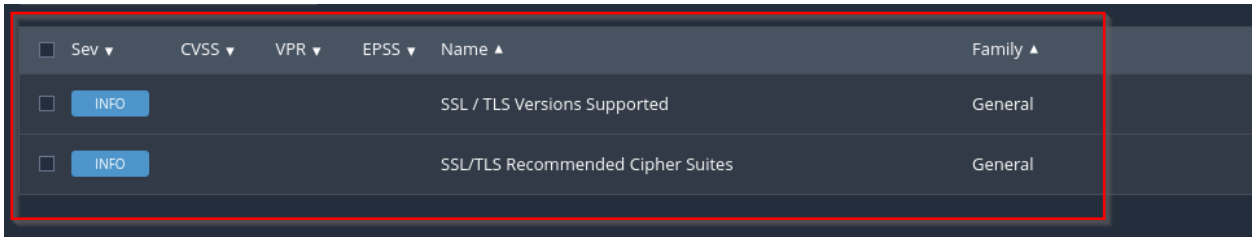

MEDIUM
SSL Anonymous Cipher Suites Supported
Description
The remote host supports the use of anonymous SSL ciphers. While this enables an administrator to set up a service that encrypts traffic without having to generate and configure SSL certificates, it offers no way to verify the remote host's identity and renders the service vulnerable to a man-in-the-middle attack.
Note: This is considerably easier to exploit if the attacker is on the same physical network.
Solution
Reconfigure the affected application if possible to avoid use of weak ciphers.

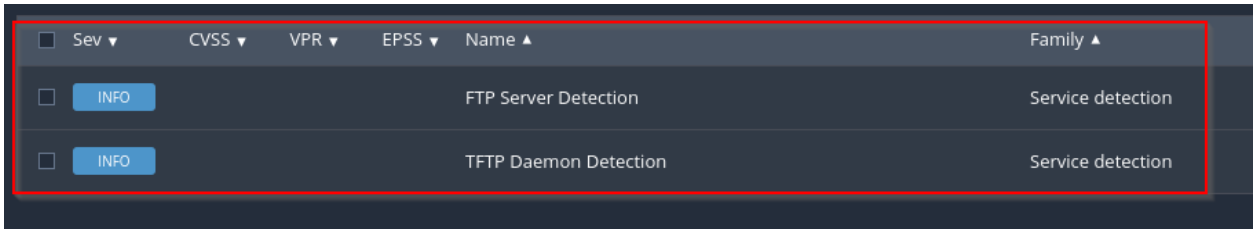

LOW
SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)
Description
The remote host allows SSL/TLS connections with one or more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections.
Solution
Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.
See Also
https://weakdh.org/


LOW
X Server Detection
Description
The remote host is running an X11 server. X11 is a client-server protocol that can be used to display graphical applications running on a given host on a remote client.
Since the X11 traffic is not ciphered, it is possible for an attacker to eavesdrop on the connection.
Solution
Restrict access to this port. If the X11 client/server facility is not used, disable TCP support in X11 entirely (-nolisten tcp).
Output

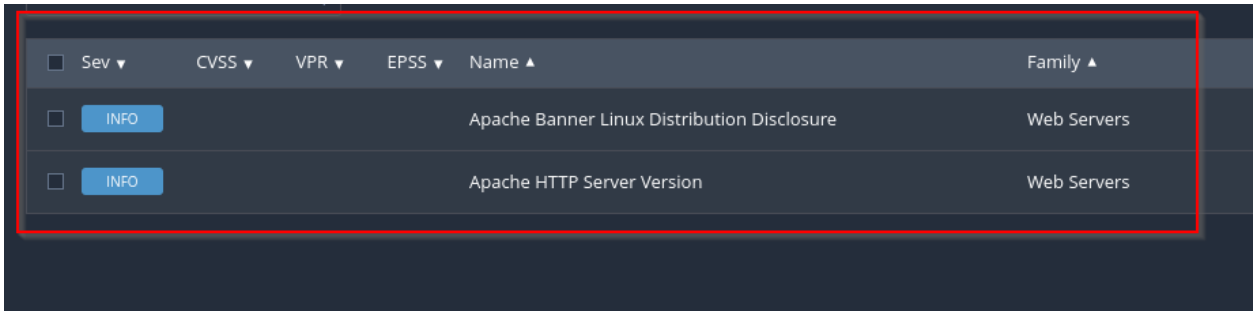

LOW
ICMP Timestamp Request Remote Date Disclosure
Description
The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.
Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.
Solution
Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).


Sev
CVSS
VPR
EPSS
Name
Family
INFO
Microsoft Windows SMB Service Detection
Windows
INFO
Microsoft Windows SMB LanMan Pipe Server Listing Disclosure
Windows
INFO
Microsoft Windows SMB NativeLanManager Remote System In...
Windows
INFO
Microsoft Windows SMB Versions Supported (remote check)
Windows
INFO
Microsoft Windows SMB2 and SMB3 Dialects Supported (remo...
Windows
INFO
Windows NetBIOS / SMB Remote Host Information Disclosure
Windows


Sev
CVSS
VPR
EPSS
Name
Family
INFO
SSL / TLS Versions Supported
General
INFO
SSL/TLS Recommended Cipher Suites
General



| Sev | CVSS | VPR | EPSS | Name | Family |
|---|---|---|---|---|---|
| INFO | | | | FTP Server Detection | Service detection |
| INFO | | | | TFTP Daemon Detection | Service detection |



| Sev | CVSS | VPR | EPSS | Name | Family |
|---|---|---|---|---|---|
| INFO | | | | Apache Banner Linux Distribution Disclosure | Web Servers |
| INFO | | | | Apache HTTP Server Version | Web Servers |